

Лабораторная работа №5-Ф. ЗАХВАТ КОНТРОЛЛЕРА ДОМЕНА 2

Кибербезопасность предприятия

Боровиков Даниил Хрусталев Влад Гисматуллин Артём Чесноков Артёмий Кон-
нова Татьяна Нефедова Наталья Уткина Алина Бансимба Клодели

Российский университет дружбы народов, Москва, Россия

- Получить доступ к контроллеру домена в сети 195.239.174.0/24
- Создать доменного пользователя hacker
- Добавить его в локальную группу Administrators
- Получить флаг в поле Comment пользователя hacker

1. **Разведка сети** – обнаружение почтового сервера Exchange (195.239.174.1)
2. **Эксплуатация ProxyLogon** – получение сессии через CVE-2021-26855
3. **Внутренняя разведка** – обнаружение AD (10.10.10.20) и CS (10.10.10.40)
4. **Обнаружение уязвимости ESC8** в AD CS
5. **NTLM Relay + PetitPotam** – получение сертификата контроллера домена
6. **Получение TGT-билета** и дампы хешей администратора
7. **Захват контроллера** через psexec с NTLM-хешем
8. **Создание пользователя hacker** и получение флага

Уязвимости: - CVE-2021-26855 (ProxyLogon) – начальный доступ - ESC8 (AD CS) – эскалация привилегий через сертификаты - PetitPotam – принуждение к аутентификации

Инструменты: - Metasploit (ProxyLogon, psexec, SOCKS proxy) - Impacket (ntlmrelayx, secretsdump, smbexec) - Certipy, PetitPotam, responder

- Получен полный доступ к контроллеру домена `ad.ampire.corp`
- Создан пользователь `hacker`, добавлен в `Administrators`
- Получен флаг: **35269** (в поле `Comment` пользователя `hacker`)

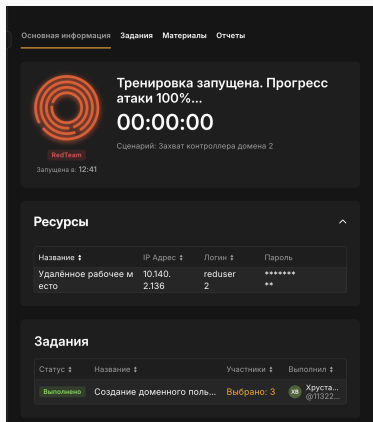


Рис. 1: Выполнение работы

Работа продемонстрировала цепочку атак от внешнего периметра до полного контроля над доменом:

1. Важность своевременного обновления Exchange Server
2. Риски некорректной настройки AD Certificate Services
3. Опасность NTLM Relay-атак и принудительной аутентификации
4. Необходимость мониторинга аномальной активности в домене

